ТУСУР
TUSUR UNIVERSITY

Организация деятельности по информационной безопасности

Управление информационной безопасностью. Лекция 2.2

6 Организация деятельности по информационной безопасности

Раздел включает в себя 2 категории и 7 мер обеспечения информационной безопасности:

6.1 Внутренняя организация деятельности по обеспечению информационной
Цель: Создать структуру органов управления для инициирования и контроля внедрения и функционирования ИБ в организации.

- 6.1.1 Роли и обязанности по обеспечению информационной безопасности
- 6.1.2 Разделение обязанностей
- 6.1.3 Взаимодействие с органами власти
- 6.1.4 Взаимодействие с профессиональными сообществами
- 6.1.5 Информационная безопасность при управлении проектом

6.2 Мобильные устройства и дистанционная работа
Цель: Обеспечить безопасность при дистанционной работе и использовании мобильных устройств.

- 6.2.1 Политика использования мобильных устройств
- 6.2.2 Дистанционная работа

Роли и обязанности по обеспечению информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Все обязанности по обеспечению ИБ должны быть определены и распределены.

Разделение обязанностей по обеспечению ИБ необходимо осуществлять в соответствии с политиками ИБ. Должны быть определены обязанности по защите конкретных активов и выполнению конкретных процессов ИБ. Там, где это необходимо, обязанности следует дополнять более подробным руководством для конкретных мест и средств обработки информации.

Лица, за которыми закреплены обязанности, связанные с ИБ, могут делегировать задачи по обеспечению безопасности другим. Но поскольку ответственность остается лежать на них, они должны удостовериться, что все делегированные задачи были выполнены корректно.

Многие организации назначают менеджера по ИБ, который в целом несет ответственность за разработку и внедрение системы менеджмента информационной безопасности и за выбор мер обеспечения ИБ.

Тем не менее, ответственность за выделение ресурсов и внедрение мер обеспечения ИБ часто ложится на отдельных менеджеров. Распространенной практикой является назначение владельца каждому активу, который затем становится ответственным за его постоянную защиту.

Роли и обязанности по обеспечению информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Должны быть определены области, за которые лица несут ответственность. В частности, следует проделать следующее:

a) активы и процессы ИБ должны быть идентифицированы и описаны;
b) для каждого актива или процесса ИБ следует назначить ответственное лицо, при этом следует детально задокументировать возложенную ответственность;
c) должны быть определены и задокументированы уровни полномочий;
d) чтобы иметь возможность выполнять возложенные обязанности, назначенные лица должны быть компетентны в области ИБ и им должна быть предоставлена возможность поддержания своих компетенций на должном уровне;
e) должны быть определены и задокументированы аспекты взаимодействия и контроля ИБ при взаимодействии с поставщиками.

Разделение обязанностей

Пересекающиеся обязанности и зоны ответственности должны быть разделены для уменьшения возможности несанкционированного или непреднамеренного изменения или нецелевого использования активов организации.

Следует позаботиться о том, чтобы одно и то же лицо не могло получить доступ к активам, изменять или использовать их без разрешения или возможности обнаружения такого действия. Инициирование события должно быть отделено от его авторизации. При разработке мер обеспечения ИБ следует учитывать возможность сговора.

Небольшие организации могут столкнуться с трудностями при разделении обязанностей, тем не менее данный принцип следует применять настолько, насколько это возможно и практически осуществимо. Там, где возникают трудности с разделением обязанностей, следует рассмотреть другие меры обеспечения ИБ, такие как мониторинг деятельности, ведение записей в журналах и контроль со стороны руководства.

Разделение обязанностей – это метод снижения риска случайного или преднамеренного ненадлежащего использования активов организации.

Взаимодействие с органами власти

Должны поддерживаться соответствующие контакты с уполномоченными органами власти.

В организациях должны действовать процедуры, определяющие, в каких случаях и кому следует связываться с органами власти (например, с правоохранительными, регулирующими или надзорными органами), и каким образом информация о выявленных инцидентах ИБ должна своевременно передаваться (например, если есть подозрения на возможное нарушение закона).

Организации, подвергающиеся атакам, вероятнее всего будут нуждаться в обращении к органам власти для принятия мер обеспечения ИБ против источника атаки.

Поддержание таких контактов может являться требованием, обеспечивающим менеджмент инцидентов ИБ или процесс непрерывности бизнеса и действий в чрезвычайных ситуациях. Взаимодействие с регулирующими органами также полезно для прогнозирования и подготовки к предстоящим изменениям в законах и нормативных актах, применимых к организации. Стоит поддерживать контакты и с другими органами, такими как коммунальные и аварийные службы, поставщики электроэнергии, службы спасения, например пожарные (в связи с обеспечением непрерывности бизнеса), провайдеры телекоммуникационных услуг (в связи с обеспечением доступности линий связи и маршрутизацией), службы водоснабжения (для обеспечения своевременного охлаждения оборудования).

Взаимодействие с профессиональными сообществами

Должно поддерживаться соответствующее взаимодействие с заинтересованными профессиональными сообществами и ассоциациями или форумами, проводимыми специалистами по безопасности.

Членство в специализированных группах или сообществах следует рассматривать как средство для:

a) получения актуальной информации о происходящем в сфере ИБ и расширения знаний о лучших практиках;
b) обеспечения актуальности и полноты понимания среды ИБ;
c) получения заблаговременных оповещений об опасностях, рекомендациях и исправлениях, касающихся атак и уязвимостей;
d) получения консультаций у специалистов по ИБ;
e) всестороннего обмена информацией о новых технологиях, продуктах, угрозах и уязвимостях;
f) обеспечения подходящих точек взаимодействия при обработке инцидентов ИБ.

Для улучшения сотрудничества и координации в вопросах безопасности могут быть заключены соглашения об обмене информацией. Такие соглашения должны определять требования к защите конфиденциальной информации.

Информационная безопасность при управлении проектом

ИБ должна рассматриваться при управлении проектом независимо от типа проекта.

ИБ должна быть интегрирована в метод(ы) управления проектами, чтобы гарантировать, что риски ИБ идентифицированы и обработаны в рамках проекта. Обычно это относится к любому проекту независимо от его характера, например проект для основного бизнес-процесса, ИТ, управления объектами и других вспомогательных процессов. Применяемые методы управления проектами должны предусматривать, что:

a) цели ИБ включены в цели проекта;
b) оценку риска ИБ проводят на ранней стадии проекта для определения необходимых вариантов его обработки;
c) ИБ является частью всех этапов применяемой методологии проекта.

Последствия для ИБ следует регулярно анализировать и пересматривать во всех проектах. Ответственность за ИБ должна быть установлена и распределена между точно определенными ролями, которые заданы в методах управления проектом.

Политика использования мобильных устройств

Должна быть определена политика и реализованы поддерживающие меры обеспечения ИБ для управления рисками ИБ, связанными с использованием мобильных устройств.

При использовании мобильных устройств особое внимание следует уделять тому, чтобы информация ограниченного доступа не была скомпрометирована. Политика использования мобильных устройств должна принимать во внимание риски работы с мобильными устройствами в незащищенных средах.

Политика использования мобильных устройств должна предусматривать:

a) регистрацию мобильных устройств;
b) требования к физической защите;
c) ограничения на установку программного обеспечения;
d) требования к версиям программного обеспечения мобильного устройства и применению исправлений;
e) ограничение подключения к информационным сервисам;
f) управление доступом;
g) криптографические методы обеспечения ИБ;
h) защиту от вредоносного программного обеспечения;
i) возможности дистанционного отключения, стирания или блокировки;
j) резервное копирование;
k) использование веб-сервисов и веб-приложений;
l) контроль получения прав "root" на устройстве.

Политика использования мобильных устройств

Следует проявлять осторожность при использовании устройств в общественных местах, конференц-залах и других незащищенных местах. Должна быть предусмотрена защита от несанкционированного доступа или раскрытия информации, хранящейся и обрабатываемой этими устройствами, например, использование криптографических методов и принудительное применение секретной аутентификационной информации.

Мобильные устройства также должны быть физически защищены от кражи, особенно если они могут быть оставлены, например, в автомобилях и других видах транспорта, в гостиничных номерах, конференц-центрах и местах для встреч. Для случаев кражи или утери мобильных устройств должна быть установлена специальная процедура, учитывающая правовые, страховые и другие требования безопасности организации. Устройства, несущие важную, ограниченную информацию, не следует оставлять без присмотра и, по возможности, их следует физически запирать или использовать специальные замки для защиты.

Следует организовать обучение персонала, использующего мобильные устройства, для повышения их осведомленности о дополнительных рисках, связанных с таким способом работы, и о мерах обеспечения ИБ, которые должны быть выполнены.

Политика использования мобильных устройств

Там, где политика допускает использование личных мобильных устройств, политика и соответствующие меры обеспечения ИБ также должны предусматривать:

a) разделение использования устройств в личных и рабочих целях, включая использование программного обеспечения для обеспечения такого разделения и защиты информации ограниченного доступа на личном устройстве;
b) предоставление доступа к информации ограниченного доступа только после того, как пользователи подпишут соглашение, признающее их обязанности (физическая защита, обновление программного обеспечения и т.д.), отказ от владения информацией ограниченного доступа, позволяющее организации дистанционно удалять данные в случае кражи или утери устройства, или когда пользователь больше не авторизован на использование. Политика должна учитывать особенности законодательства по защите конфиденциальной информации.

Меры обеспечения ИБ для мобильных устройств, как правило, состоят из адаптированных мер, которые используются в стационарных устройствах и тех, которые предназначены для устранения угроз, возникающих при их использовании вне помещений организации.

Дистанционная работа

Должна быть определена политика и реализованы поддерживающие меры безопасности для защиты информации, доступ к которой, обработку или хранение осуществляют в местах дистанционной работы.

К термину "дистанционная работа" относятся все формы работы вне офиса, в том числе нетрадиционная рабочая среда, такая как "работа на дому", "гибкое рабочее место" и "виртуальное рабочее место".

Дистанционная работа

В организациях, предусматривающих возможность дистанционной работы, должна издаваться политика, определяющая условия и ограничения для дистанционной работы. В тех случаях, когда это применимо и разрешено законом, следует рассмотреть следующие вопросы:

a) существующая физическая защита удаленного места работы с учетом физической безопасности здания и местности;
b) предлагаемая физическая среда дистанционной работы;
c) требования к безопасности связи с учетом необходимости удаленного доступа к внутренним системам организации, чувствительности этих систем, а также с учетом информации ограниченного доступа, к которой будут осуществлять доступ и которую будут передавать по линиям связи;
d) предоставление доступа к виртуальному рабочему столу, который предотвращает обработку и хранение информации на личном оборудовании;
e) угроза несанкционированного доступа к информации или ресурсам со стороны других лиц, находящихся в этом же помещении, например членов семьи или друзей;
f) использование домашних сетей и установление требований или ограничений на конфигурацию сервисов беспроводных сетей;
g) политики и процедуры для предотвращения споров, касающихся прав на интеллектуальную собственность, разработанную на личном оборудовании;
h) доступ к личному оборудованию (для проверки его безопасности или в ходе расследования) может быть запрещен законодательством;
i) лицензионные соглашения на программное обеспечение, в соответствии с которыми организация может нести ответственность за лицензирование клиентского программного обеспечения на личных рабочих станциях работников или внешних пользователей;
j) требования к защите от вредоносных программ и межсетевым экранам.

Дистанционная работа

Руководящие принципы и меры, которые следует учитывать, должны включать в себя:

a) предоставление подходящего оборудования для дистанционной работы и устройств хранения в тех случаях, когда использование личного оборудования, не находящегося под контролем организации, не допускается;
b) определение разрешенных работ, часов работы, категорий информации, которую можно обрабатывать, а также определение внутренних систем и сервисов, к которым разрешен доступ дистанционному работнику;
c) предоставление соответствующего коммуникационного оборудования, включая способы обеспечения безопасного удаленного доступа;
d) физическую безопасность;
e) правила и рекомендации по доступу членов семьи и посетителей к оборудованию и информации;
f) предоставление технической и программной поддержки и обслуживания;
g) страхование;
h) процедуры резервного копирования и обеспечения непрерывности бизнеса;
i) аудит и мониторинг безопасности;
j) аннулирование полномочий и прав доступа, а также возврат оборудования по окончании дистанционной работы;
k) предоставление доступа к корпоративной информации.

Рассмотренные вопросы

Организация деятельности по информационной безопасности:

- Роли и обязанности по обеспечению информационной безопасности. Разделение обязанностей.
- Взаимодействие с органами власти и профессиональными сообществами
- Политика использования мобильных устройств и дистанционная работа

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!